

PASO 1

INTEGRA

Infraestructura de Trazabilidad e Identidad para la Gestión de Recursos de Asignación

Análisis de Amenazas

Identificación de riesgos en la cadena de suministro de donación de órganos

Blockchain + Ciberseguridad + IoT · Cadena de Suministro de Donación de Órganos en América Latina

Propuesta de implementación: Argentina — Modelo replicable para América Latina

Metodología: STRIDE · MITRE ATT&CK Enterprise v14 · CVSS v3.1 adaptado

1. Introducción y Contexto

INTEGRA es un proyecto cuyo objetivo final es proveer a América Latina de una infraestructura de trazabilidad, identidad y ciberseguridad para la cadena de suministro de donación de órganos. Por razones de contexto institucional, conectividad y marco regulatorio, la propuesta se desarrolla con Argentina como caso de implementación concreto — con una coordinadora nacional de trasplantes como organismo rector hipotético de referencia — pero está diseñada desde su origen como un modelo replicable en los países de la región.

La cadena de suministro de donación de órganos no es solo logística médica. Es un sistema de información crítica que moviliza identidades, datos clínicos sensibles, autorizaciones legales y coordinación entre múltiples actores institucionales. En ese contexto, cada nodo del proceso es un vector de ataque potencial.

En América Latina, la mayoría de esos nodos operan sin protección adecuada. Este documento presenta el análisis de amenazas como primer paso para el diseño de la solución INTEGRA, que integra Blockchain, IoT y ciberseguridad embebida para proteger el proceso de extremo a extremo.

1.1 Alcance del análisis

El análisis cubre el proceso completo desde la muerte del donante hasta el registro post-operatorio del trasplante, incluyendo:

- Registro y verificación del donante
- Coordinación nacional de asignación
- Asignación al receptor por compatibilidad
- Traslado físico del órgano (logística y IoT)
- Recepción y validación en hospital destino
- Registro post-operatorio y auditoría

1.2 Contexto regional

La OMS estima que entre el 5% y el 10% de los trasplantes mundiales ocurren en el mercado negro. En América Latina, la manipulación de listas de espera es un mecanismo documentado. Los incidentes de ransomware en infraestructura de salud de la región son crecientes: el ataque de Conti al sistema de salud de

Costa Rica (2022) y el de Rhysida a una obra social de Argentina (2023) son casos de referencia directa para este análisis.

Argentina fue seleccionada como caso de implementación piloto por contar con la coordinadora nacional de trasplantes — con un registro de trasplantes estructurado — y por tener un marco de datos de salud aplicable (Ley 25326). Los hallazgos y la arquitectura son aplicables con adaptaciones a los sistemas de coordinación de trasplantes de Brasil, México y Colombia.

2. Modelo de Amenazas — Metodología STRIDE

STRIDE es la metodología desarrollada por Microsoft para categorizar sistemáticamente los tipos de amenaza en sistemas de información. Se aplica aquí al dominio específico de la donación de órganos en el contexto latinoamericano, con foco en las vulnerabilidades de un sistema nacional de trasplantes como referencia concreta.

Letra	Categoría	Descripción general	Amenaza específica al dominio	Nivel
S	Spoofing / Suplantación	Suplantación de identidad de usuarios o sistemas.	Médico falso accede con credenciales robadas. Falsificación de identidad de donante.	CRÍTICO
T	Tampering / Manipulación	Alteración no autorizada de datos en tránsito o en reposo.	Modificación de lista de espera. Alteración de compatibilidad HLA.	CRÍTICO
R	Repudiation / Repudio	Negación de haber realizado una acción sin posibilidad de refutación.	Actor interno niega haber modificado asignación. Sin logs inmutables ni firma digital.	ALTO
I	Info Disclosure / Exposición	Revelación de información a partes no autorizadas.	Fuga de datos de pacientes en lista de espera. Exposición de rutas de traslado.	ALTO
D	Denial of Service / Denegación	Interrupción de la disponibilidad del sistema.	Ransomware durante coordinación activa de trasplante. DDoS al registro nacional.	CRÍTICO
E	Elevation of Privilege / Escalada	Obtención de permisos superiores a los asignados.	IT tercerizado con acceso irrestricto a BD clínica. Movimiento lateral a red clínica.	ALTO

2.1 Spoofing — Suplantación de Identidad

La ausencia de mecanismos de autenticación fuerte hace que las credenciales robadas sean suficientes para operar como un actor legítimo dentro del sistema. En Argentina, el 90% de las instalaciones hospitalarias opera con usuario y contraseña como único factor de autenticación.

- Médico o coordinador falso accede al sistema con credenciales obtenidas mediante phishing
- Falsificación de identidad del donante para manipular datos de compatibilidad en favor de un receptor específico
- Suplantación de la coordinadora nacional de trasplantes para emitir autorizaciones fraudulentas
- Spear phishing dirigido al personal de trasplante: correos personalizados con adjuntos maliciosos

2.2 Tampering — Manipulación de Datos

Este es el vector de mayor impacto directo sobre vidas humanas. La lista de espera de la coordinadora nacional de trasplantes es el activo más crítico y, en su estado actual, es una base de datos relacional modificable por usuarios con privilegios sin trazabilidad inmutable.

- Alteración de la lista de espera para favorecer a receptores con capacidad de pago o por corrupción directa
- Modificación de datos de compatibilidad HLA o grupo sanguíneo para dirigir asignaciones
- Manipulación de registros de tiempo de isquemia para ocultar demoras o irregularidades
- Alteración de logs de auditoría post-incidente para eliminar evidencia de manipulación
- Inyección de datos falsos desde dispositivos IoT comprometidos en el traslado

2.3 Repudiation — Repudio

Sin registros inmutables y sin firma digital obligatoria, es imposible probar quién realizó una acción en el sistema. Esta es la base técnica de la impunidad ante manipulaciones de datos.

- Actor interno niega haber modificado una asignación: no hay log criptográficamente firmado que lo acredite
- Falta de cadena de custodia digital del órgano durante el traslado
- Sin firma digital, ninguna autorización de trasplante es técnicamente no-repudiable

2.4 Information Disclosure — Exposición de Información

- Fuga de datos de pacientes en lista de espera: pueden usarse para extorsión o discriminación
- Exposición de rutas de traslado del órgano en tiempo real: facilita interceptación física
- Datos clínicos transmitidos en texto plano mediante HL7 v2 sin capa de cifrado adicional
- Acceso no autorizado a bases de datos de compatibilidad genética

2.5 Denial of Service — Denegación de Servicio

Un ataque de disponibilidad en el sector salud tiene consecuencias directas sobre vidas. El tiempo de isquemia de un corazón es de 4 a 6 horas; el de un riñón, 24 a 36 horas. Cualquier interrupción de sistemas durante ese período puede ser fatal.

- Ransomware activado durante coordinación activa de trasplante: paraliza la operación en ventana crítica
- DDoS al sistema de registro nacional en momentos de alta actividad
- Interrupción de conectividad de dispositivos IoT en contenedores de transporte del órgano

2.6 Elevation of Privilege — Escalada de Privilegios

- Técnico de empresa IT tercerizada con acceso irrestricto a base de datos clínica sin segmentación
- Explotación de vulnerabilidades en software de gestión hospitalaria para obtener acceso de administrador
- Cuentas con privilegios excesivos que no respetan el principio de mínimo acceso

- Movimiento lateral desde la red administrativa hacia la red clínica

3. Mapa de Superficies de Ataque

El proceso de donación de órganos involucra múltiples nodos interconectados, cada uno con su propio perfil de riesgo. El siguiente mapa sigue el flujo operativo del proceso en el contexto de un sistema nacional de trasplantes, aunque es directamente aplicable a los sistemas equivalentes en Brasil, México y Colombia.

Nodo del proceso	Nivel de riesgo	Vulnerabilidades principales	Vector de ataque
Hospital donante	CRÍTICO	Sin MFA. Protocolos HL7 v2 sin cifrado. Red clínica no segmentada.	Phishing al personal. Acceso físico a terminales.
La coordinadora nacional de trasplantes	CRÍTICO	Lista de espera mutable. Sin auditoría inmutable. Acceso privilegiado sin control.	Insider con acceso directo a BD. Movimiento lateral desde red perimetral.
Sistema de asignación	CRÍTICO	Reglas de compatibilidad manipulables. Sin firma digital en decisiones. Sin trazabilidad.	Modificación directa de parámetros. Inyección SQL en portales legacy.
Traslado del órgano	ALTO	Ruta de traslado expuesta. Dispositivos IoT sin autenticación. Comunicaciones sin cifrado.	Intercepción de comunicaciones. Compromiso de sensores IoT.
Hospital receptor	ALTO	Verificación manual sin respaldo criptográfico. Sistemas legacy sin soporte.	Aceptación de órgano con documentación falsificada. Acceso no autorizado.
Registro post-operatorio	MEDIO	Datos sin hash de integridad. Auditoría manual susceptible a manipulación.	Alteración retroactiva de registros para ocultar irregularidades.

4. Actores de Amenaza — Perfiles en Contexto Latinoamericano

Actor	Motivación	Probabilidad	Impacto	Tácticas / Casos de referencia
Insider Corrupto	Financiera / Coerción	ALTA	CRÍTICO	Modificación directa de BD. Eliminación de logs. Provisión de acceso a terceros. Casos documentados en coordinadoras de Argentina, Brasil y México.
Grupo de Ransomware Organizado	Extorsión económica	MUY ALTA	CRÍTICO	Cifrado de sistemas durante ventana de isquemia. Conti → Costa Rica (2022). Rhysida → obra social Argentina (2023). LockBit → hospitales Brasil.
Red de Tráfico de Órganos	Comercial (USD 150k–300k/unidad)	MEDIA-ALTA	CRÍTICO	Corrupción de insiders. Robo de datos de compatibilidad. Falsificación de identidades. OMS estima 10% de trasplantes en mercado informal.
Script Kiddie / Oportunista	Notoriedad	ALTA	BAJO-MEDIO	Explotación de vulnerabilidades sin parchear. Fuerza bruta. Defacement de portales.
Proveedor IT Comprometido	Supply chain / acceso heredado	MEDIA	ALTO	Backdoor en mantenimiento de sistemas. Acceso privilegiado sin control. Exfiltración de datos.
Actor Estatal / APT	Espionaje genético / Sabotaje	BAJA	CATASTRÓFICO	Sabotaje de infraestructura crítica. Robo masivo de datos genéticos. Técnicas avanzadas de evasión.

5. Matriz de Riesgo — Probabilidad × Impacto

Probabilidad / Impacto	Bajo	Moderado	Alto	Catastrófico
Muy Alta	Defacement web pública	Phishing masivo a personal médico	Ransomware hospitalario	Ransomware en coordinación activa de trasplante
Alta	Escaneo de puertos externo	Fuga de datos administrativos	Insider manipula lista de espera	Falsificación de compatibilidad HLA
Media	Credential stuffing fallido	Exfiltración de datos clínicos	Intercepción ruta de traslado	Manipulación IoT cadena de frío
Baja	Spam institucional	Acceso no autorizado a logs	Supply chain IT comprometido	Actor estatal / APT

Fondo rojo = Riesgo Crítico · Fondo naranja = Riesgo Alto · Fondo gris/blanco = Riesgo Bajo-Moderado

5.1 Prioridades de intervención

De la matriz surgen cuatro riesgos que requieren intervención inmediata:

- Ransomware durante coordinación activa de trasplante — Prioridad #1
- Insider que manipula la lista de espera — Prioridad #2
- Falsificación de datos de compatibilidad HLA — Prioridad #3
- Ransomware hospitalario general — Prioridad #4

6. Mapeo MITRE ATT&CK — Tácticas y Técnicas

ID Táctica	Táctica	ID Técnica	Técnica aplicada al dominio
TA0001	Initial Access	T1566 / T1190 / T1195	Phishing a coordinadores médicos / Exploit de portales web / Supply chain en software clínico
TA0003	Persistence	T1078 / T1547 / T1136	Uso de cuentas válidas (insiders) / Backdoor en sistemas de registro / Creación de cuentas de servicio ocultas
TA0004	Privilege Escalation	T1068 / T1134 / T1484	Explotación de vulnerabilidades locales / Manipulación de tokens / Abuso de políticas de dominio débiles
TA0006	Credential Access	T1110 / T1552 / T1539	Fuerza bruta a portales clínicos / Credenciales en archivos de config / Robo de session tokens
TA0007	Discovery	T1046 / T1082 / T1083	Escaneo de red hospitalaria interna / Fingerprinting de sistemas legacy / Enumeración de archivos clínicos
TA0008	Lateral Movement	T1021 / T1080 / T1563	Movimiento vía RDP/VNC expuesto / Contaminación de recursos compartidos / Secuestro de sesiones remotas
TA0009	Collection	T1005 / T1213 / T1125	Exfiltración local de datos clínicos / Scraping de repositorios / Captura de datos IoT
TA0040	Impact	T1485 / T1486 / T1565	Destrucción de datos críticos / Ransomware — cifrado de sistemas / Manipulación de datos clínicos

Referencia: MITRE ATT&CK Enterprise Framework v14 — enterprise.attack.mitre.org

7. Ranking de Vulnerabilidades — Contexto Latinoamericano

Score	Vulnerabilidad	Impacto principal	Descripción contextual
9.8	Lista de espera mutable sin auditoría inmutable	Integridad + No-repudio	No existe registro inmutable de quién modifica la lista ni cuándo. Vector directo del tráfico de influencias.
9.5	Ausencia de MFA en acceso a sistemas críticos	Autenticación	El 90%+ de instalaciones usa solo usuario/contraseña. Credenciales robadas = acceso total al sistema.
9.2	Comunicación clínica sin cifrado (HL7 v2)	Confidencialidad	HL7 v2 no tiene seguridad nativa. Datos en tránsito legibles en texto plano en la red.
8.7	Ransomware sin plan de respuesta a incidentes	Disponibilidad	Sin IRP documentado, hospitales pierden días de operación. En trasplante, horas perdidas = vidas.
8.4	Acceso privilegiado de IT tercerizado sin control	Control de acceso	Proveedores externos con acceso total a BD clínica sin segmentación, logging ni revisión periódica.
8.1	Dispositivos IoT de transporte sin autenticación	Integridad + Disponibilidad	Sensores en contenedores transmiten sin cifrado ni autenticación. Datos manipulables o interceptables.
7.6	Sistemas legacy sin soporte (Windows XP/7)	Todos los pilares	SO obsoletos sin parches. Vulnerabilidades conocidas sin corregir en equipos médicos en producción.
7.1	Sin interoperabilidad segura entre países	Autenticación + Integridad	Trasplantes internacionales coordinados por canales no estandarizados ni seguros.

8. Conclusiones del Análisis de Amenazas

8.1 Hallazgo principal

El mayor riesgo identificado no es el atacante externo sofisticado. Es la combinación de insider con acceso legítimo y ausencia de trazabilidad inmutable. Este hallazgo fundamenta directamente el uso de blockchain como componente de INTEGRA: no como tendencia tecnológica, sino como respuesta técnica precisa a una amenaza concreta y documentada.

La detección de comportamiento anómalo sobre los logs del sistema es un problema que las reglas fijas no resuelven completamente: un insider que opera dentro de sus horarios habituales pero con patrones de acceso inusuales puede no disparar ninguna alerta predefinida. La inteligencia artificial aplicada sobre el flujo de eventos del ledger resuelve exactamente ese gap, identificando desviaciones estadísticas que ninguna regla manual anticiparía.

8.2 Los tres vectores críticos a neutralizar

- **Manipulación de la lista de espera:** requiere registro inmutable con firma digital obligatoria en cada modificación (blockchain)
- **Acceso no autorizado con credenciales robadas:** requiere autenticación fuerte (MFA) y gestión de identidad criptográfica
- **Disponibilidad ante ransomware:** requiere arquitectura resiliente con nodos distribuidos y plan de continuidad operativa

8.3 Aplicabilidad del modelo a América Latina

Aunque la propuesta toma a Argentina como caso de implementación concreto, el análisis de amenazas es directamente aplicable a los sistemas de los demás países de la región. Las vulnerabilidades identificadas — ausencia de MFA, HL7 v2 sin cifrado, listas de espera mutables, IT tercerizado sin control — son transversales a toda la infraestructura de trasplantes latinoamericana. El modelo INTEGRA está diseñado para ser replicado con las adaptaciones regulatorias e institucionales correspondientes a cada país.

8.4 Limitaciones del alcance tecnológico

La tecnología puede cerrar brechas de seguridad técnica, pero no puede por sí sola resolver la corrupción institucional profunda, la falta de conectividad en zonas rurales ni la resistencia al cambio organizacional. La solución INTEGRA debe diseñarse reconociendo estas limitaciones y priorizando los vectores donde la intervención técnica tiene impacto real.

Nota metodológica: los scores de severidad son estimaciones contextuales basadas en CVSS v3.1 adaptado al entorno operacional de salud pública latinoamericana. No corresponden a CVEs específicos. El mapeo MITRE ATT&CK corresponde al Enterprise Framework v14 (2024). Las referencias institucionales de este documento son hipotéticas y genéricas — no identifican a una organización real ni implican su participación en el proyecto.